

WebPwn Advanced Pentest Report

Target: https://sso.aztu.edu.az/

Date: 2026-05-13 00:10 | Generated by WebPwn Senior Pentest Module

Executive Summary

This report presents the findings of an advanced automated security assessment against https://sso.aztu.edu.az/. The assessment utilized senior-level heuristics to identify critical vulnerabilities across OWASP Top 10 categories. A total of 86 security findings were recorded.

Severity	Count
CRITICAL	26
HIGH	12
MEDIUM	11
LOW	2
INFO	58

Detailed Security Findings

#1 [CRITICAL] Command Injection (Output-Based)

Location: https://sso.aztu.edu.az/Home/Login

CVSS Score: 9.8

Technical Details: Parameter 'UserId' is injectable — payload: ';\$IFS\$(id'

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Never pass user-supplied input to shell commands. Use parameterised APIs (subprocess with list args). Apply strict allowlist validation on all inputs.

#2 [CRITICAL] Command Injection (Output-Based)

Location: https://sso.aztu.edu.az/Home/Login

CVSS Score: 9.8

Technical Details: Parameter 'UserId' is injectable — payload: '{ls,-la,/}'

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Never pass user-supplied input to shell commands. Use parameterised APIs (subprocess with list args). Apply strict allowlist validation on all inputs.

#3 [CRITICAL] Command Injection (Output-Based)

Location: <https://sso.aztu.edu.az/Home/Login>

CVSS Score: 9.8

Technical Details: Parameter 'UserId' is injectable — payload: '& PING /n 3 127.0.0.1'

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Never pass user-supplied input to shell commands. Use parameterised APIs (subprocess with list args). Apply strict allowlist validation on all inputs.

#4 [CRITICAL] XSS — Session Hijack Payload (Generated)

Location: <https://sso.aztu.edu.az>

CVSS Score: 9.3

Technical Details: XSS confirmed in 'q'. Cookie-stealing payload generated. Attacker can capture session tokens of authenticated users.

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Implement strict CSP. Sanitize all output. Set HttpOnly + Secure flags on all session cookies.

#5 [CRITICAL] SQLi — Data Extraction (Exploited)

Location: <https://sso.aztu.edu.az>

CVSS Score: 10.0

Technical Details: SQLi successfully exploited. Extracted: {'version': 'Giri■', 'user': 'Giri■', 'databases': 'Giri■', 'tables': 'Giri■', 'dump_users': 'Giri■'}

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

IMMEDIATELY patch. Use parameterized queries.

#6 [CRITICAL] CHAIN: XSS → CSRF → Account Takeover

Location: <https://sso.aztu.edu.az>

CVSS Score: 9.8

Technical Details: XSS allows attacker to steal CSRF tokens from victim's browser DOM, then forge authenticated state-changing requests (password reset, email change) without victim's knowledge — leading to full account takeover.

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Implement strict CSP (Content-Security-Policy). Use SameSite=Strict cookies. Enforce CSRF tokens even when XSS is patched (defense in depth).

#7 [CRITICAL] CHAIN: SQLi → Credential Dump → Admin Takeover

Location: <https://sso.aztu.edu.az/Home/Login>

CVSS Score: 10.0

Technical Details: SQL injection allows dumping the users/credentials table. Cracked or plaintext credentials can be used to log in as admin, achieving full application compromise.

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Use parameterized queries. Hash passwords with bcrypt/argon2. Enforce MFA on admin accounts.

#8 [CRITICAL] CHAIN: IDOR → PII Exfiltration → Mass Account Hijack

Location: <https://sso.aztu.edu.az/Home/Login>

CVSS Score: 9.1

Technical Details: Insecure Direct Object References allow attackers to enumerate user IDs and access other users' data (emails, addresses, payment info). At scale, this enables mass PII exfiltration and account takeover.

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Implement authorization checks on every resource access. Use UUID instead of sequential IDs. Log and alert on anomalous data access patterns.

#9 [CRITICAL] CHAIN: JWT None Algorithm → Admin Privilege Escalation

Location: <https://sso.aztu.edu.az/Home/Login>

CVSS Score: 9.8

Technical Details: JWT with 'alg:none' or weak HS256 secret allows forging tokens with arbitrary claims (e.g. role:admin). This bypasses all role-based access controls.

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Enforce RS256/ES256 algorithms. Reject 'none' algorithm. Validate all JWT claims server-side. Use short expiration times.

#10 [CRITICAL] SQLi — Data Extraction (Exploited)

Location: <https://sso.aztu.edu.az/Home/Login>

CVSS Score: 10.0

Technical Details: SQLi successfully exploited. Extracted: {'version': 'cannot', 'user': 'cannot', 'databases': 'cannot', 'tables': 'cannot', 'dump_users': 'cannot'}

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

IMMEDIATELY patch. Use parameterized queries.

#11 [HIGH] GCP Bucket

Location: <https://storage.googleapis.com/sso-public>

CVSS Score: N/A

Technical Details: GCP Bucket status: Open — <https://storage.googleapis.com/sso-public>

[!] Attacker Impact / Scenario:

Publicly accessible cloud storage buckets (S3/GCP/Azure) can expose sensitive files, customer data, or application assets to unauthorized access or modification.

[+] Strategic Remediation:

Set bucket/blob ACL to private. Enable bucket versioning and logging. Use signed URLs for authorized access only.

#12 [HIGH] GCP Bucket

Location: <https://storage.googleapis.com/sso-images>

CVSS Score: N/A

Technical Details: GCP Bucket status: Open — <https://storage.googleapis.com/sso-images>

[!] Attacker Impact / Scenario:

Publicly accessible cloud storage buckets (S3/GCP/Azure) can expose sensitive files, customer data, or application assets to unauthorized access or modification.

[+] Strategic Remediation:

Set bucket/blob ACL to private. Enable bucket versioning and logging. Use signed URLs for authorized access only.

#13 [HIGH] Exposed Path: /wp-config.php

Location: <https://sso.aztu.edu.az/wp-config.php>

CVSS Score: 7.5

Technical Details: Path exists but is forbidden — worth further investigation

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Move sensitive files outside web root. Never deploy .env to production.

#14 [HIGH] Missing Header: Content-Security-Policy

Location: <https://sso.aztu.edu.az>

CVSS Score: 7.5

Technical Details: CSP prevents XSS and data injection attacks by controlling allowed resource sources.

[!] Attacker Impact / Scenario:

Missing security headers expose users to MIME-sniffing, Clickjacking, and Cross-Site Scripting. It weakens the client-side security posture significantly.

[+] Strategic Remediation:

Configure the web server to emit standard security headers: Content-Security-Policy (CSP), X-Frame-Options, X-Content-Type-Options: nosniff, and Strict-Transport-Security (HSTS).

#15 [HIGH] Missing Header: Strict-Transport-Security

Location: <https://sso.aztu.edu.az>

CVSS Score: 7.5

Technical Details: HSTS forces HTTPS connections and prevents SSL-stripping attacks.

[!] Attacker Impact / Scenario:

Missing security headers expose users to MIME-sniffing, Clickjacking, and Cross-Site Scripting. It weakens the client-side security posture significantly.

[+] Strategic Remediation:

Configure the web server to emit standard security headers: Content-Security-Policy (CSP), X-Frame-Options, X-Content-Type-Options: nosniff, and Strict-Transport-Security (HSTS).

#16 [HIGH] CSRF — Missing CSRF Token

Location: <https://sso.aztu.edu.az/Home/Login>

CVSS Score: 8.1

Technical Details: State-changing POST form at 'https://sso.aztu.edu.az/Home/Login' has no CSRF token field.

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Implement synchronizer token pattern (per-session or per-request CSRF tokens). Set SameSite=Strict on session cookies. Validate Origin/Referer on all state-changing endpoints. Use custom request headers (X-Requested-With) as secondary defense.

#17 [HIGH] CVE: CVE-2008-4765

Location: <https://nvd.nist.gov/vuln/detail/CVE-2008-4765>

CVSS Score: 7.5 | **CVE:** CVE-2008-4765 (See NVD for details)

Technical Details: CVE-2008-4765 affects 'Not disclosed' — SQL injection vulnerability in pollBooth.php in osCommerce Poll Booth Add-On 2.0 allows remote attackers to execute arbitrary SQL commands via the pollID parameter in a results operation. NOTE: this

[!] Attacker Impact / Scenario:

Attackers can exploit this known vulnerability (CVE) to execute remote code, read sensitive server files, or hijack user sessions. This puts the entire infrastructure and customer data at critical risk.

[+] Strategic Remediation:

Immediately apply the official vendor patch for the identified technology. If patching is not immediately possible, apply WAF virtual patching and restrict access to the vulnerable component.

#18 [HIGH] CVE: CVE-2008-4804

Location: <https://nvd.nist.gov/vuln/detail/CVE-2008-4804>

CVSS Score: 7.5 | **CVE:** CVE-2008-4804 (See NVD for details)

Technical Details: CVE-2008-4804 affects 'Not disclosed' — SQL injection vulnerability in the Gallery module 1.3 for PHP-Nuke allows remote attackers to execute arbitrary SQL commands via the aid parameter in a showalbum action to index.php. NOTE: some of th

[!] Attacker Impact / Scenario:

Attackers can exploit this known vulnerability (CVE) to execute remote code, read sensitive server files, or hijack user sessions. This puts the entire infrastructure and customer data at critical risk.

[+] Strategic Remediation:

Immediately apply the official vendor patch for the identified technology. If patching is not immediately possible, apply WAF virtual patching and restrict access to the vulnerable component.

#19 [HIGH] 2FA — No Rate Limiting on OTP (Brute-force Possible)

Location: <https://sso.aztu.edu.az/>

CVSS Score: 7.5

Technical Details: Tested 7 OTP codes with no lockout or 429 response.

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Enforce max 5 attempts. Add exponential backoff and account lockout.

#20 [HIGH] CHAIN: CORS Misconfiguration → XSS → Session Theft

Location: https://sso.aztu.edu.az

CVSS Score: 8.8

Technical Details: Permissive CORS allows malicious origins to make authenticated API requests. Combined with XSS, attacker can send victim's session cookies to a controlled server via cross-origin fetch.

[!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

[+] Strategic Remediation:

Restrict CORS to trusted origins. Do not use wildcard (*) with credentials. Set HttpOnly + Secure + SameSite on cookies.

#21 [MEDIUM] Exposed Path: /robots.txt

Location: <https://sso.aztu.edu.az/robots.txt>

CVSS Score: 5.3

Technical Details: Path accessible with HTTP 200

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Review if this path should be publicly accessible. Add authentication if needed.

#22 [MEDIUM] No Account Lockout

Location: <https://sso.aztu.edu.az/Home/Login>

CVSS Score: 5.3

Technical Details: 6 consecutive failed logins did not trigger lockout or CAPTCHA

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Implement account lockout after 3-5 failed attempts. Add CAPTCHA or progressive delays.

#23 [MEDIUM] Missing Header: X-Frame-Options

Location: <https://sso.aztu.edu.az>

CVSS Score: 6.1

Technical Details: Missing X-Frame-Options allows clickjacking attacks (embedding site in iframes).

[!] Attacker Impact / Scenario:

Missing security headers expose users to MIME-sniffing, Clickjacking, and Cross-Site Scripting. It weakens the client-side security posture significantly.

[+] Strategic Remediation:

Configure the web server to emit standard security headers: Content-Security-Policy (CSP), X-Frame-Options, X-Content-Type-Options: nosniff, and Strict-Transport-Security (HSTS).

#24 [MEDIUM] CVE: CVE-2006-3147

Location: <https://nvd.nist.gov/vuln/detail/CVE-2006-3147>

CVSS Score: 6.5 | **CVE:** CVE-2006-3147 (See NVD for details)

Technical Details: CVE-2006-3147 affects 'Not disclosed' — Unspecified vulnerability in Hosting Controller before 6.1 (aka Hotfix 3.2) allows remote authenticated attackers to gain host admin privileges, list all resellers, or change resellers' passwords via

[!] Attacker Impact / Scenario:

Attackers can exploit this known vulnerability (CVE) to execute remote code, read sensitive server files, or hijack user sessions. This puts the entire infrastructure and customer data at critical risk.

[+] Strategic Remediation:

Immediately apply the official vendor patch for the identified technology. If patching is not immediately possible, apply WAF virtual patching and restrict access to the vulnerable component.

#25 [MEDIUM] CVE: CVE-2008-4299

Location: <https://nvd.nist.gov/vuln/detail/CVE-2008-4299>

CVSS Score: 5.0 | **CVE:** CVE-2008-4299 (See NVD for details)

Technical Details: CVE-2008-4299 affects 'Not disclosed' — A certain ActiveX control in the Microsoft Internet Authentication Service (IAS) Helper COM Component in iashlpr.dll allows remote attackers to cause a denial of service (browser crash) via a large in

[!] Attacker Impact / Scenario:

Attackers can exploit this known vulnerability (CVE) to execute remote code, read sensitive server files, or hijack user sessions. This puts the entire infrastructure and customer data at critical risk.

[+] Strategic Remediation:

Immediately apply the official vendor patch for the identified technology. If patching is not immediately possible, apply WAF virtual patching and restrict access to the vulnerable component.

#26 [MEDIUM] CVE: CVE-2008-4300

Location: <https://nvd.nist.gov/vuln/detail/CVE-2008-4300>

CVSS Score: 5.0 | **CVE:** CVE-2008-4300 (See NVD for details)

Technical Details: CVE-2008-4300 affects 'Not disclosed' — A certain ActiveX control in adsiis.dll in Microsoft Internet Information Services (IIS) allows remote attackers to cause a denial of service (browser crash) via a long string in the second argument t

[!] Attacker Impact / Scenario:

Attackers can exploit this known vulnerability (CVE) to execute remote code, read sensitive server files, or hijack user sessions. This puts the entire infrastructure and customer data at critical risk.

[+] Strategic Remediation:

Immediately apply the official vendor patch for the identified technology. If patching is not immediately possible, apply WAF virtual patching and restrict access to the vulnerable component.

#27 [MEDIUM] 2FA — Not Implemented

Location: <https://sso.aztu.edu.az>

CVSS Score: 5.9

Technical Details: No 2FA/MFA endpoint detected.

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Implement TOTP-based 2FA (FIDO2/WebAuthn/RFC 6238) for all accounts.

#28 [MEDIUM] PostMessage — Page is Frameable (Clickjacking + postMessage Risk)

Location: <https://sso.aztu.edu.az>

CVSS Score: 5.4

Technical Details: No X-Frame-Options or CSP frame-ancestors header found. Attacker can embed this page in a frame and use postMessage to inject data into any vulnerable message listeners.

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Add 'X-Frame-Options: DENY' or CSP 'frame-ancestors none'.

#29 [MEDIUM] Admin Login Panel Exposed

Location: <https://sso.aztu.edu.az/admin>

CVSS Score: 5.3

Technical Details: Admin login form found at <https://sso.aztu.edu.az/admin> — brute-force attempted, no weak creds found

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Restrict admin panel to known IP ranges. Implement account lockout and MFA.

#30 [LOW] Missing Header: X-Content-Type-Options

Location: <https://sso.aztu.edu.az>

CVSS Score: 3.1

Technical Details: Missing header allows MIME-type sniffing, enabling content injection.

[!] Attacker Impact / Scenario:

Missing security headers expose users to MIME-sniffing, Clickjacking, and Cross-Site Scripting. It weakens the client-side security posture significantly.

[+] Strategic Remediation:

Configure the web server to emit standard security headers: Content-Security-Policy (CSP), X-Frame-Options, X-Content-Type-Options: nosniff, and Strict-Transport-Security (HSTS).

#31 [LOW] Missing Header: Referrer-Policy

Location: <https://sso.aztu.edu.az>

CVSS Score: 3.1

Technical Details: Missing Referrer-Policy may leak sensitive URL information to third parties.

[!] Attacker Impact / Scenario:

Missing security headers expose users to MIME-sniffing, Clickjacking, and Cross-Site Scripting. It weakens the client-side security posture significantly.

[+] Strategic Remediation:

Configure the web server to emit standard security headers: Content-Security-Policy (CSP), X-Frame-Options, X-Content-Type-Options: nosniff, and Strict-Transport-Security (HSTS).

#32 [INFO] Port Scan

Location: sso.aztu.edu.az:53

CVSS Score: N/A

Technical Details: Port 53 is open (DNS) — Banner:

[!] Attacker Impact / Scenario:

Exposed network services increase the attack surface. SSH, HTTP, and non-standard ports can be exploited for brute-force, service fingerprinting, and lateral movement.

[+] Strategic Remediation:

Restrict port access via firewall rules. Only expose necessary services. Harden SSH with key-based auth and disable root login.

#33 [INFO] Port Scan

Location: sso.aztu.edu.az:80

CVSS Score: N/A

Technical Details: Port 80 is open (HTTP) — Banner: HTTP/1.1 403 Forbidden

[!] Attacker Impact / Scenario:

Exposed network services increase the attack surface. SSH, HTTP, and non-standard ports can be exploited for brute-force, service fingerprinting, and lateral movement.

[+] Strategic Remediation:

Restrict port access via firewall rules. Only expose necessary services. Harden SSH with key-based auth and disable root login.

#34 [INFO] Port Scan

Location: sso.aztu.edu.az:443

CVSS Score: N/A

Technical Details: Port 443 is open (HTTPS) — Banner: HTTP/1.1 400 Bad Request

[!] Attacker Impact / Scenario:

Exposed network services increase the attack surface. SSH, HTTP, and non-standard ports can be exploited for brute-force, service fingerprinting, and lateral movement.

[+] Strategic Remediation:

Restrict port access via firewall rules. Only expose necessary services. Harden SSH with key-based auth and disable root login.

#35 [INFO] Port Scan

Location: sso.aztu.edu.az:8080

CVSS Score: N/A

Technical Details: Port 8080 is open (HTTP Proxy) — Banner: HTTP/1.1 403 Forbidden

[!] Attacker Impact / Scenario:

Exposed network services increase the attack surface. SSH, HTTP, and non-standard ports can be exploited for brute-force, service fingerprinting, and lateral movement.

[+] Strategic Remediation:

Restrict port access via firewall rules. Only expose necessary services. Harden SSH with key-based auth and disable root login.

#36 [INFO] Port Scan

Location: sso.aztu.edu.az:8443

CVSS Score: N/A

Technical Details: Port 8443 is open (HTTPS Alt) — Banner: HTTP/1.1 400 Bad Request

[!] Attacker Impact / Scenario:

Exposed network services increase the attack surface. SSH, HTTP, and non-standard ports can be exploited for brute-force, service fingerprinting, and lateral movement.

[+] Strategic Remediation:

Restrict port access via firewall rules. Only expose necessary services. Harden SSH with key-based auth and disable root login.

#37 [INFO] Tech Detect

Location: https://sso.aztu.edu.az/

CVSS Score: N/A

Technical Details: Technology detected: Not disclosed

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Follow security best practices and ensure all inputs are sanitized and dependencies updated.

#38 [INFO] Web Crawler

Location: https://sso.aztu.edu.az/

CVSS Score: N/A

Technical Details: -

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Follow security best practices and ensure all inputs are sanitized and dependencies updated.

#39 [INFO] AWS S3

Location: http://sso-dev.s3.amazonaws.com

CVSS Score: N/A

Technical Details: AWS S3 status: Exists (Access Denied) — http://sso-dev.s3.amazonaws.com

[!] Attacker Impact / Scenario:

Publicly accessible cloud storage buckets (S3/GCP/Azure) can expose sensitive files, customer data, or application assets to unauthorized access or modification.

[+] Strategic Remediation:

Set bucket/blob ACL to private. Enable bucket versioning and logging. Use signed URLs for authorized access only.

#40 [INFO] AWS S3

Location: <http://sso-staging.s3.amazonaws.com>

CVSS Score: N/A

Technical Details: AWS S3 status: Exists (Access Denied) — <http://sso-staging.s3.amazonaws.com>

[!] Attacker Impact / Scenario:

Publicly accessible cloud storage buckets (S3/GCP/Azure) can expose sensitive files, customer data, or application assets to unauthorized access or modification.

[+] Strategic Remediation:

Set bucket/blob ACL to private. Enable bucket versioning and logging. Use signed URLs for authorized access only.

#41 [INFO] AWS S3

Location: <http://sso-prod.s3.amazonaws.com>

CVSS Score: N/A

Technical Details: AWS S3 status: Exists (Access Denied) — <http://sso-prod.s3.amazonaws.com>

[!] Attacker Impact / Scenario:

Publicly accessible cloud storage buckets (S3/GCP/Azure) can expose sensitive files, customer data, or application assets to unauthorized access or modification.

[+] Strategic Remediation:

Set bucket/blob ACL to private. Enable bucket versioning and logging. Use signed URLs for authorized access only.

#42 [INFO] AWS S3

Location: <http://sso-assets.s3.amazonaws.com>

CVSS Score: N/A

Technical Details: AWS S3 status: Exists (Access Denied) — <http://sso-assets.s3.amazonaws.com>

[!] Attacker Impact / Scenario:

Publicly accessible cloud storage buckets (S3/GCP/Azure) can expose sensitive files, customer data, or application assets to unauthorized access or modification.

[+] Strategic Remediation:

Set bucket/blob ACL to private. Enable bucket versioning and logging. Use signed URLs for authorized access only.

#43 [INFO] AWS S3

Location: <http://sso-test.s3.amazonaws.com>

CVSS Score: N/A

Technical Details: AWS S3 status: Exists (Access Denied) — <http://sso-test.s3.amazonaws.com>

[!] Attacker Impact / Scenario:

Publicly accessible cloud storage buckets (S3/GCP/Azure) can expose sensitive files, customer data, or application assets to unauthorized access or modification.

[+] Strategic Remediation:

Set bucket/blob ACL to private. Enable bucket versioning and logging. Use signed URLs for authorized access only.

#44 [INFO] AWS S3

Location: <http://sso-media.s3.amazonaws.com>

CVSS Score: N/A

Technical Details: AWS S3 status: Exists (Access Denied) — <http://sso-media.s3.amazonaws.com>

[!] Attacker Impact / Scenario:

Publicly accessible cloud storage buckets (S3/GCP/Azure) can expose sensitive files, customer data, or application assets to unauthorized access or modification.

[+] Strategic Remediation:

Set bucket/blob ACL to private. Enable bucket versioning and logging. Use signed URLs for authorized access only.

#45 [INFO] AWS S3

Location: <http://sso.s3.amazonaws.com>

CVSS Score: N/A

Technical Details: AWS S3 status: Exists (Access Denied) — <http://sso.s3.amazonaws.com>

[!] Attacker Impact / Scenario:

Publicly accessible cloud storage buckets (S3/GCP/Azure) can expose sensitive files, customer data, or application assets to unauthorized access or modification.

[+] Strategic Remediation:

Set bucket/blob ACL to private. Enable bucket versioning and logging. Use signed URLs for authorized access only.

#46 [INFO] AWS S3

Location: <http://sso-private.s3.amazonaws.com>

CVSS Score: N/A

Technical Details: AWS S3 status: Exists (Access Denied) — <http://sso-private.s3.amazonaws.com>

[!] Attacker Impact / Scenario:

Publicly accessible cloud storage buckets (S3/GCP/Azure) can expose sensitive files, customer data, or application assets to unauthorized access or modification.

[+] Strategic Remediation:

Set bucket/blob ACL to private. Enable bucket versioning and logging. Use signed URLs for authorized access only.

#47 [INFO] AWS S3

Location: <http://sso-images.s3.amazonaws.com>

CVSS Score: N/A

Technical Details: AWS S3 status: Exists (Access Denied) — <http://sso-images.s3.amazonaws.com>

[!] Attacker Impact / Scenario:

Publicly accessible cloud storage buckets (S3/GCP/Azure) can expose sensitive files, customer data, or application assets to unauthorized access or modification.

[+] Strategic Remediation:

Set bucket/blob ACL to private. Enable bucket versioning and logging. Use signed URLs for authorized access only.

#48 [INFO] AWS S3

Location: <http://ssoprod.s3.amazonaws.com>

CVSS Score: N/A

Technical Details: AWS S3 status: Exists (Access Denied) — <http://ssoprod.s3.amazonaws.com>

[!] Attacker Impact / Scenario:

Publicly accessible cloud storage buckets (S3/GCP/Azure) can expose sensitive files, customer data, or application assets to unauthorized access or modification.

[+] Strategic Remediation:

Set bucket/blob ACL to private. Enable bucket versioning and logging. Use signed URLs for authorized access only.

#49 [INFO] GCP Bucket

Location: <https://storage.googleapis.com/sso-prod>

CVSS Score: N/A

Technical Details: GCP Bucket status: Exists (Access Denied) — <https://storage.googleapis.com/sso-prod>

[!] Attacker Impact / Scenario:

Publicly accessible cloud storage buckets (S3/GCP/Azure) can expose sensitive files, customer data, or application assets to unauthorized access or modification.

[+] Strategic Remediation:

Set bucket/blob ACL to private. Enable bucket versioning and logging. Use signed URLs for authorized access only.

#50 [INFO] GCP Bucket

Location: <https://storage.googleapis.com/sso-assets>

CVSS Score: N/A

Technical Details: GCP Bucket status: Exists (Access Denied) — <https://storage.googleapis.com/sso-assets>

[!] Attacker Impact / Scenario:

Publicly accessible cloud storage buckets (S3/GCP/Azure) can expose sensitive files, customer data, or application assets to unauthorized access or modification.

[+] Strategic Remediation:

Set bucket/blob ACL to private. Enable bucket versioning and logging. Use signed URLs for authorized access only.

#51 [INFO] GCP Bucket

Location: <https://storage.googleapis.com/sso-dev>

CVSS Score: N/A

Technical Details: GCP Bucket status: Exists (Access Denied) — <https://storage.googleapis.com/sso-dev>

[!] Attacker Impact / Scenario:

Publicly accessible cloud storage buckets (S3/GCP/Azure) can expose sensitive files, customer data, or application assets to unauthorized access or modification.

[+] Strategic Remediation:

Set bucket/blob ACL to private. Enable bucket versioning and logging. Use signed URLs for authorized access only.

#52 [INFO] GCP Bucket

Location: <https://storage.googleapis.com/ssotest>

CVSS Score: N/A

Technical Details: GCP Bucket status: Exists (Access Denied) — <https://storage.googleapis.com/ssotest>

[!] Attacker Impact / Scenario:

Publicly accessible cloud storage buckets (S3/GCP/Azure) can expose sensitive files, customer data, or application assets to unauthorized access or modification.

[+] Strategic Remediation:

Set bucket/blob ACL to private. Enable bucket versioning and logging. Use signed URLs for authorized access only.

#53 [INFO] Azure Blob

Location: <https://sso.blob.core.windows.net/>

CVSS Score: N/A

Technical Details: Azure Blob status: Exists — <https://sso.blob.core.windows.net/>

[!] Attacker Impact / Scenario:

Publicly accessible cloud storage buckets (S3/GCP/Azure) can expose sensitive files, customer data, or application assets to unauthorized access or modification.

[+] Strategic Remediation:

Set bucket/blob ACL to private. Enable bucket versioning and logging. Use signed URLs for authorized access only.

#54 [INFO] Azure Blob

Location: <https://ssoprod.blob.core.windows.net/>

CVSS Score: N/A

Technical Details: Azure Blob status: Exists — <https://ssoprod.blob.core.windows.net/>

[!] Attacker Impact / Scenario:

Publicly accessible cloud storage buckets (S3/GCP/Azure) can expose sensitive files, customer data, or application assets to unauthorized access or modification.

[+] Strategic Remediation:

Set bucket/blob ACL to private. Enable bucket versioning and logging. Use signed URLs for authorized access only.

#55 [INFO] GCP Bucket

Location: <https://storage.googleapis.com/sso-backup>

CVSS Score: N/A

Technical Details: GCP Bucket status: Exists (Access Denied) — <https://storage.googleapis.com/sso-backup>

[!] Attacker Impact / Scenario:

Accessible backup files can expose full database dumps, source code, credentials, and configuration secrets. This is a critical data exposure risk.

[+] Strategic Remediation:

Remove all backup files from the web root. Store backups in a secure, non-public storage location with access controls.

#56 [INFO] GCP Bucket

Location: <https://storage.googleapis.com/sso-staging>

CVSS Score: N/A

Technical Details: GCP Bucket status: Exists (Access Denied) — <https://storage.googleapis.com/sso-staging>

[!] Attacker Impact / Scenario:

Publicly accessible cloud storage buckets (S3/GCP/Azure) can expose sensitive files, customer data, or application assets to unauthorized access or modification.

[+] Strategic Remediation:

Set bucket/blob ACL to private. Enable bucket versioning and logging. Use signed URLs for authorized access only.

#57 [INFO] AWS S3

Location: <http://ssobackup.s3.amazonaws.com>

CVSS Score: N/A

Technical Details: AWS S3 status: Exists (Access Denied) — <http://ssobackup.s3.amazonaws.com>

[!] Attacker Impact / Scenario:

Accessible backup files can expose full database dumps, source code, credentials, and configuration secrets. This is a critical data exposure risk.

[+] Strategic Remediation:

Remove all backup files from the web root. Store backups in a secure, non-public storage location with access controls.

#58 [INFO] GCP Bucket

Location: <https://storage.googleapis.com/ssobackup>

CVSS Score: N/A

Technical Details: GCP Bucket status: Exists (Access Denied) — <https://storage.googleapis.com/ssobackup>

[!] Attacker Impact / Scenario:

Accessible backup files can expose full database dumps, source code, credentials, and configuration secrets. This is a critical data exposure risk.

[+] Strategic Remediation:

Remove all backup files from the web root. Store backups in a secure, non-public storage location with access controls.

#59 [INFO] Infrastructure

Location: <https://sso.aztu.edu.az/>

CVSS Score: N/A

Technical Details: Company: 172.67.176.0/20

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Follow security best practices and ensure all inputs are sanitized and dependencies updated.

#60 [INFO] IP Prefixes

Location: <https://sso.aztu.edu.az/>

CVSS Score: N/A

Technical Details: 2a09:bac0:71::/48, 172.64.68.0/24, 2a09:bac0:719::/48, 172.68.220.0/24, 2400:cb00:285::/48, 2400:cb00:a4b1::/48, 2400:cb00:cb89::/48, 2400:cb00:1048::/48, 2400:cb00:904::/48, 172.70.240.0/24...

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Follow security best practices and ensure all inputs are sanitized and dependencies updated.

#61 [INFO] Exposed Path: /log

Location: <https://sso.aztu.edu.az/log>

CVSS Score: 0.0

Technical Details: Path accessible with HTTP 301

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Review if this path should be publicly accessible. Add authentication if needed.

#62 [INFO] Exposed Path: /scripts

Location: <https://sso.aztu.edu.az/scripts>

CVSS Score: 0.0

Technical Details: Path accessible with HTTP 301

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Review if this path should be publicly accessible. Add authentication if needed.

#63 [INFO] Exposed Path: /fonts

Location: <https://sso.aztu.edu.az/fonts>

CVSS Score: 0.0

Technical Details: Path accessible with HTTP 301

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Review if this path should be publicly accessible. Add authentication if needed.

#64 [INFO] Exposed Path: /admin

Location: <https://sso.aztu.edu.az/admin>

CVSS Score: 0.0

Technical Details: Path accessible with HTTP 302

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Review if this path should be publicly accessible. Add authentication if needed.

#65 [INFO] Exposed Path: /admin/

Location: <https://sso.aztu.edu.az/admin/>

CVSS Score: 0.0

Technical Details: Path accessible with HTTP 302

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Review if this path should be publicly accessible. Add authentication if needed.

#66 [INFO] Missing Header: Permissions-Policy

Location: <https://sso.aztu.edu.az>

CVSS Score: 2.0

Technical Details: Missing Permissions-Policy allows access to powerful browser APIs (camera, mic, etc.).

[!] Attacker Impact / Scenario:

Missing security headers expose users to MIME-sniffing, Clickjacking, and Cross-Site Scripting. It weakens the client-side security posture significantly.

[+] Strategic Remediation:

Configure the web server to emit standard security headers: Content-Security-Policy (CSP), X-Frame-Options, X-Content-Type-Options: nosniff, and Strict-Transport-Security (HSTS).

#67 [INFO] Missing Header: Cross-Origin-Opener-Policy

Location: <https://sso.aztu.edu.az>

CVSS Score: 2.0

Technical Details: Missing COOP allows cross-origin pages to access window references.

[!] Attacker Impact / Scenario:

Missing security headers expose users to MIME-sniffing, Clickjacking, and Cross-Site Scripting. It weakens the client-side security posture significantly.

[+] Strategic Remediation:

Configure the web server to emit standard security headers: Content-Security-Policy (CSP), X-Frame-Options, X-Content-Type-Options: nosniff, and Strict-Transport-Security (HSTS).

#68 [INFO] Missing Header: Cross-Origin-Resource-Policy

Location: <https://sso.aztu.edu.az>

CVSS Score: 2.0

Technical Details: Missing CORP allows cross-origin pages to load this site's resources.

[!] Attacker Impact / Scenario:

Missing security headers expose users to MIME-sniffing, Clickjacking, and Cross-Site Scripting. It weakens the client-side security posture significantly.

[+] Strategic Remediation:

Configure the web server to emit standard security headers: Content-Security-Policy (CSP), X-Frame-Options, X-Content-Type-Options: nosniff, and Strict-Transport-Security (HSTS).

#69 [INFO] Information Disclosure: X-Powered-By

Location: <https://sso.aztu.edu.az>

CVSS Score: 2.0

Technical Details: Server technology disclosure may aid attacker fingerprinting.

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Remove X-Powered-By header from all responses.

#70 [INFO] Information Disclosure: Server

Location: <https://sso.aztu.edu.az>

CVSS Score: 2.0

Technical Details: Server version disclosure may aid attacker fingerprinting.

[!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

[+] Strategic Remediation:

Configure web server to omit or genericize the Server header.

#71 [INFO] WAF Detected

Location: <https://sso.aztu.edu.az/>

CVSS Score: 0.0

Technical Details: Web Application Firewall identified: Cloudflare. 0/8 attack payloads blocked.

[!] Attacker Impact / Scenario:

Attackers can bypass the Web Application Firewall using encoded payloads (Hex, Base64, Unicode). This renders the WAF ineffective and exposes the backend to direct injection attacks.

[+] Strategic Remediation:

Update WAF rulesets to decode and normalize all incoming traffic before signature analysis. Ensure strict input validation on the backend regardless of WAF presence.

#72 [INFO] WAF Bypass Technique — Cloudflare

Location: <https://sso.aztu.edu.az/>

CVSS Score: 0.0

Technical Details: Bypass technique for Cloudflare: URL double-encode: %253Cscript%253E

[!] Attacker Impact / Scenario:

Attackers can bypass the Web Application Firewall using encoded payloads (Hex, Base64, Unicode). This renders the WAF ineffective and exposes the backend to direct injection attacks.

[+] Strategic Remediation:

Update WAF rulesets to decode and normalize all incoming traffic before signature analysis. Ensure strict input validation on the backend regardless of WAF presence.

#73 [INFO] WAF Bypass Technique — Cloudflare

Location: <https://sso.aztu.edu.az/>

CVSS Score: 0.0

Technical Details: Bypass technique for Cloudflare: Unicode fullwidth: `■script■alert(1)■/script■`

[!] Attacker Impact / Scenario:

Attackers can bypass the Web Application Firewall using encoded payloads (Hex, Base64, Unicode). This renders the WAF ineffective and exposes the backend to direct injection attacks.

[+] Strategic Remediation:

Update WAF rulesets to decode and normalize all incoming traffic before signature analysis. Ensure strict input validation on the backend regardless of WAF presence.

#74 [INFO] WAF Bypass Technique — Cloudflare

Location: <https://sso.aztu.edu.az/>

CVSS Score: 0.0

Technical Details: Bypass technique for Cloudflare: Case mixing: `<ScRiPt>alert(1)</sCrIpT>`

[!] Attacker Impact / Scenario:

Attackers can bypass the Web Application Firewall using encoded payloads (Hex, Base64, Unicode). This renders the WAF ineffective and exposes the backend to direct injection attacks.

[+] Strategic Remediation:

Update WAF rulesets to decode and normalize all incoming traffic before signature analysis. Ensure strict input validation on the backend regardless of WAF presence.

#75 [INFO] WAF Bypass Technique — Cloudflare

Location: <https://sso.aztu.edu.az/>

CVSS Score: 0.0

Technical Details: Bypass technique for Cloudflare: Chunked Transfer-Encoding with TE: chunked header

[!] Attacker Impact / Scenario:

Attackers can bypass the Web Application Firewall using encoded payloads (Hex, Base64, Unicode). This renders the WAF ineffective and exposes the backend to direct injection attacks.

[+] Strategic Remediation:

Update WAF rulesets to decode and normalize all incoming traffic before signature analysis. Ensure strict input validation on the backend regardless of WAF presence.

#76 [INFO] WAF Bypass Technique — Cloudflare

Location: <https://sso.aztu.edu.az/>

CVSS Score: 0.0

Technical Details: Bypass technique for Cloudflare: JSON content-type with GET body bypass

[!] Attacker Impact / Scenario:

Attackers can bypass the Web Application Firewall using encoded payloads (Hex, Base64, Unicode). This renders the WAF ineffective and exposes the backend to direct injection attacks.

[+] Strategic Remediation:

Update WAF rulesets to decode and normalize all incoming traffic before signature analysis. Ensure strict input validation on the backend regardless of WAF presence.

#77 [INFO] WAF Bypass Technique — Cloudflare

Location: <https://sso.aztu.edu.az/>

CVSS Score: 0.0

Technical Details: Bypass technique for Cloudflare: HTTP/2 header smuggling (H2.CL)

[!] Attacker Impact / Scenario:

Attackers can bypass the Web Application Firewall using encoded payloads (Hex, Base64, Unicode). This renders the WAF ineffective and exposes the backend to direct injection attacks.

[+] Strategic Remediation:

Update WAF rulesets to decode and normalize all incoming traffic before signature analysis. Ensure strict input validation on the backend regardless of WAF presence.

#78 [INFO] WAF Bypass Payload — URL-encoded

Location: https://sso.aztu.edu.az/

CVSS Score: 0.0

Technical Details: Encoded variant: %3Cscript%3Ealert%281%29%3C/script%3E

[!] Attacker Impact / Scenario:

Attackers can bypass the Web Application Firewall using encoded payloads (Hex, Base64, Unicode). This renders the WAF ineffective and exposes the backend to direct injection attacks.

[+] Strategic Remediation:

Update WAF rulesets to decode and normalize all incoming traffic before signature analysis. Ensure strict input validation on the backend regardless of WAF presence.

#79 [INFO] WAF Bypass Payload — Double URL-encoded

Location: https://sso.aztu.edu.az/

CVSS Score: 0.0

Technical Details: Encoded variant: %253Cscript%253Ealert%25281%2529%253C/script%253E

[!] Attacker Impact / Scenario:

Attackers can bypass the Web Application Firewall using encoded payloads (Hex, Base64, Unicode). This renders the WAF ineffective and exposes the backend to direct injection attacks.

[+] Strategic Remediation:

Update WAF rulesets to decode and normalize all incoming traffic before signature analysis. Ensure strict input validation on the backend regardless of WAF presence.

#80 [INFO] WAF Bypass Payload — HTML-entity

Location: https://sso.aztu.edu.az/

CVSS Score: 0.0

Technical Details: Encoded variant: <script>alert(1)</script>

[!] Attacker Impact / Scenario:

Attackers can bypass the Web Application Firewall using encoded payloads (Hex, Base64, Unicode). This renders the WAF ineffective and exposes the backend to direct injection attacks.

[+] Strategic Remediation:

Update WAF rulesets to decode and normalize all incoming traffic before signature analysis. Ensure strict input validation on the backend regardless of WAF presence.

#81 [INFO] WAF Bypass Payload — Unicode escape

Location: https://sso.aztu.edu.az/

CVSS Score: 0.0

Technical Details: Encoded variant: <script>alert(1)</script>

[!] Attacker Impact / Scenario:

Attackers can bypass the Web Application Firewall using encoded payloads (Hex, Base64, Unicode). This renders the WAF ineffective and exposes the backend to direct injection attacks.

[+] Strategic Remediation:

Update WAF rulesets to decode and normalize all incoming traffic before signature analysis. Ensure strict input validation on the backend regardless of WAF presence.

#82 [INFO] WAF Bypass Payload — Hex (JS)

Location: <https://sso.aztu.edu.az/>

CVSS Score: 0.0

Technical Details: Encoded variant:

`\x3c\x73\x63\x72\x69\x70\x74\x3e\x61\x6c\x65\x72\x74\x28\x31\x29\x3c\x2f\x73\x63\x72\x69\x70\x74\x3e`

[!] Attacker Impact / Scenario:

Attackers can bypass the Web Application Firewall using encoded payloads (Hex, Base64, Unicode). This renders the WAF ineffective and exposes the backend to direct injection attacks.

[+] Strategic Remediation:

Update WAF rulesets to decode and normalize all incoming traffic before signature analysis. Ensure strict input validation on the backend regardless of WAF presence.

#83 [INFO] WAF Bypass Payload — Base64

Location: <https://sso.aztu.edu.az/>

CVSS Score: 0.0

Technical Details: Encoded variant: PHNjcmlwdD5hbGVydCgxKTWvc2NyaXB0Pg==

[!] Attacker Impact / Scenario:

Attackers can bypass the Web Application Firewall using encoded payloads (Hex, Base64, Unicode). This renders the WAF ineffective and exposes the backend to direct injection attacks.

[+] Strategic Remediation:

Update WAF rulesets to decode and normalize all incoming traffic before signature analysis. Ensure strict input validation on the backend regardless of WAF presence.

#84 [INFO] WAF Bypass Payload — Null-byte

Location: <https://sso.aztu.edu.az/>

CVSS Score: 0.0

Technical Details: Encoded variant: `■<script>alert(1)■</script>`

[!] Attacker Impact / Scenario:

Attackers can bypass the Web Application Firewall using encoded payloads (Hex, Base64, Unicode). This renders the WAF ineffective and exposes the backend to direct injection attacks.

[+] Strategic Remediation:

Update WAF rulesets to decode and normalize all incoming traffic before signature analysis. Ensure strict input validation on the backend regardless of WAF presence.

#85 [INFO] WAF Bypass Payload — Tab-obfuscated

Location: <https://sso.aztu.edu.az/>

CVSS Score: 0.0

Technical Details: Encoded variant: `<scr ipt>alert(1)</scr ipt>`

[!] Attacker Impact / Scenario:

Attackers can bypass the Web Application Firewall using encoded payloads (Hex, Base64, Unicode). This renders the WAF ineffective and exposes the backend to direct injection attacks.

[+] Strategic Remediation:

Update WAF rulesets to decode and normalize all incoming traffic before signature analysis. Ensure strict input validation on the backend regardless of WAF presence.

#86 [INFO] WAF Bypass Payload — Case-mixed

Location: <https://sso.aztu.edu.az/>

CVSS Score: 0.0

Technical Details: Encoded variant: `<sCrIpT>AlErT(1)</ScRiPt>`

[!] Attacker Impact / Scenario:

Attackers can bypass the Web Application Firewall using encoded payloads (Hex, Base64, Unicode). This renders the WAF ineffective and exposes the backend to direct injection attacks.

[+] Strategic Remediation:

Update WAF rulesets to decode and normalize all incoming traffic before signature analysis. Ensure strict input validation on the backend regardless of WAF presence.
